

Activos de información a proteger

Activo: cualquier información o sistema informático **de valor** para la empresa.
Incluye todo lo que se debe proteger en la empresa (datos, aplicaciones, memorias, equipos, redes):



Vulnerabilidad: debilidad, agujero de seguridad o **fallo de un sistema que puede ser aprovechado con fines maliciosos.**

Cada vulnerabilidad se identifica mediante un código **CVE** (Common Vulnerabilities and Exposures), que es un estándar desarrollado por la corporación no gubernamental MITRE. Podemos buscar el detalle de una vulnerabilidad en concreto a partir de su código CVE:

https://cve.mitre.org/cve/search_cve_list.html

<https://www.cvedetails.com>

<https://nvd.nist.gov/vuln/search>



Ejemplo: busca a qué se refiere la vulnerabilidad CVE-2009-3129

Y la vulnerabilidad CVE-2018-5390 <https://www.muyseguridad.net/2018/08/08/fallo-tcp-linux-freebsd-denegacion-de-servicio>

Ejemplo: <https://www.incibe.es/protege-tu-empresa/blog/30-mayores-vulnerabilidades>

Amenaza: circunstancia desfavorable que puede ocurrir sobre los activos comprometiendo su seguridad.

Puede **tener causas naturales, ser accidental o se intencionada.**

Si existe **una vulnerabilidad** puede derivar en un **incidente de seguridad.**

Riesgo: es la posibilidad de que una **amenaza o vulnerabilidad se convierta en un daño real** para la empresa (pérdida o robo de información o detención de su actividad - disponibilidad).

El riesgo puede ser **mitigado** con estas medidas:

- Definiendo **Políticas de seguridad** (prevención – medidas activas, procedimientos)
- Aplicando medidas de **Continuidad del negocio** (paliación – medidas pasivas)

Gestión de activos de información – Inventario de activos:

No se puede proteger lo que no se conoce. El primer paso para prevenir incidentes es **identificar todos los activos** de la empresa (HW y SW) para crear un **Inventario de activos** actualizado. Tipos de activos: <https://isowin.org/blog/activos-ISO-27001>

Para cada activo de la empresa se debe indicar en el **inventario**:

- **Nombre del activo**
- **Tipo de activo:**
 - o Información – archivo - BBDD
 - o Aplicación o servicio
 - o Soporte de memoria (disco, memoria USB, cabina NAS...)
 - o Equipo informático (servidor, PC, portátil, tablet, raspi...)
 - o Equipo de comunicaciones de red (router, switch, AP Wi-Fi...)
- **Ubicación** (oficina, sede, despacho, CPD, armario rack, domicilio)
- **Propietario/responsable del activo y restricciones** de acceso (quién puede qué)
- **Nivel de importancia** (criticidad) del activo para la empresa: indicar si es alto, medio, bajo. El nivel de cada activo se determina evaluando qué impacto tendría la pérdida de su confidencialidad, integridad o disponibilidad.
- **Nivel de seguridad** actual del activo: indicar su nivel de Confidencialidad, Integridad y Disponibilidad. Podemos usar la siguiente matriz para determinar el nivel de seguridad de cada activo y determinar si es el adecuado:

	MUY BAJO	BAJO	MEDIO	ALTO	MUY ALTO
Confidencialidad	El activo tiene un mínimo grado de sensibilidad para la organización por lo que afecta casi de forma imperceptible la operación, la economía o aspectos de cumplimiento.	El activo tiene un bajo grado de sensibilidad para la organización por lo que afecta de cierta forma la operación, la economía o aspectos de cumplimiento.	El activo tiene un mediano grado de sensibilidad para la organización por lo que afecta la operación, la economía o aspectos de cumplimiento.	El activo tiene un alto grado de sensibilidad para la organización por lo que afecta considerablemente la operación, la economía o aspectos de cumplimiento.	El activo tiene un muy alto grado de sensibilidad para la organización por lo que afecta totalmente la operación, la economía o aspectos de cumplimiento.
Integridad	Si el activo no mantiene su integridad afecta casi de forma imperceptible la operación, la economía o aspectos de cumplimiento.	Si el activo no mantiene su integridad afecta de cierta forma la operación, la economía o aspectos de cumplimiento.	El activo debe tener un mediano nivel de integridad porque si no afectaría la operación, la economía o aspectos de cumplimiento.	El activo requiere de un alto nivel de integridad, porque si no afectaría considerablemente la operación, la economía o aspectos de cumplimiento.	El activo debe tener un muy alto nivel de integridad porque si no afectaría totalmente la operación, la economía o aspectos de cumplimiento.
Disponibilidad	El activo no es crítico para la organización y no afecta casi de forma imperceptible la operación, la economía o el cumplimiento.	El activo tiene criticidad baja para la organización y afecta de cierta forma la operación, la economía o el cumplimiento.	El activo tiene criticidad media para la organización y afecta la operación, la economía o el cumplimiento.	El activo tiene criticidad alta para la organización y afecta considerablemente la operación, la economía o el cumplimiento.	El activo tiene criticidad muy alta para la organización y afecta totalmente la operación, la economía o el cumplimiento.

Esta matriz permite determinar si la seguridad del activo es la adecuada

Finalmente se deben definir **procedimientos** para el uso correcto de los activos de forma que se preserve su seguridad. Un procedimiento es una **guía detallada** que describe cómo **implementar una medida** o control de seguridad sobre un activo.

Todos los aspectos de la gestión de activos vienen recogidos en la norma estándar **ISO 27001** para la Seguridad de la Información. La ISO 27001 describe cómo **implementar un SGSI** (Sistema de Gestión de la Seguridad de la Información) en una empresa.



La norma describe los **objetivos de seguridad a conseguir** en la empresa y los **controles** que hay que realizar **para verificar** que se cumplen los objetivos.

<https://normaiso27001.es/a8-gestion-de-activos>

A.7 GESTIÓN DE ACTIVOS		
A.7.1 Responsabilidad por los activos		
Objetivo: lograr y mantener la protección apropiada de los activos organizacionales.		
A.7.1.1	Inventario de activos	Control Todos los activos se deben identificar claramente y se debe elaborar y mantener un inventario de todos los activos importantes.
A.7.1.2	Dueños de los activos	Control Toda la información y activos asociados con las instalaciones de procesamiento de información deben tener un "dueño", que es la parte designada de la organización.
A.7.1.3	Uso aceptable de los activos	Control Se deben identificar, documentar e implementar las reglas para el uso aceptable de información y activos asociados con las instalaciones de procesamiento de información.
A.7.2 Clasificación de la información		
Objetivo: asegurar que la información reciba un nivel apropiado de protección.		
A.7.2.1	Directrices para clasificación	Control La información se debe clasificar en cuanto a su valor, requisitos legales, sensibilidad y criticidad para el sistema.
A.7.2.2	Etiquetado y manejo de información	Control Se debe desarrollar e implementar un conjunto apropiado de procedimientos para etiquetado y manejo de la información, de acuerdo con el esquema de clasificación adoptado por la organización.

Ejemplo: documento de inventario de activos para la empresa Líder Tecnología:

FORMATO DE CLASIFICACIÓN DE ACTIVOS BASADO EN LA NORMA ISO 27001 PARA UN SISTEMA DE GESTIÓN DE SEGURIDAD DE LA INFORMACIÓN

ESCALA DE MEDICIÓN	
Mínimo	1
Bajo	2
Medio	3
Alto	4
Muy Alto	5

PONDERACIÓN PROPIEDADES	
Confidencialidad	33%
Integridad	33%
Disponibilidad	33%

ASPECTOS ORGANIZACIONALES	
Operación	33%
Economía	33%
Cumplimiento	33%

ATRIBUTOS DEL ACTIVO					CLASIFICACIÓN		
Nombre Activo	Tipo de activo	Ubicación	Propietario	Custodio	Propiedad	Clasificación Propiedad	Clasificación del activo
SAP	Software	Servidor SAP	Líder Tecnología	Analista de aplicaciones	Confidencialidad	Bajo	Alto
					Integridad	Medio	
					Disponibilidad	Medio	
Servidor SAP	Hardware	Data center	Líder Tecnología	Administrador de sistemas	Confidencialidad	Medio	Medio
					Integridad	Medio	
					Disponibilidad	Medio	
Router de acceso a Internet	Hardware	Data center	Líder Tecnología	Administrador de sistemas	Confidencialidad	Bajo	Medio
					Integridad	Medio	
					Disponibilidad	Medio	
Cabinas NAS para backups	Hardware	Data center	Líder Tecnología	Administrador de sistemas	Confidencialidad	Medio	Medio
					Integridad	Medio	
					Disponibilidad	Medio	

Se debe **asegurar primero los activos más importantes** aplicándoles todo tipo de medidas de seguridad.



Los datos (información) suelen ser **el activo más importante** para la empresa; ya que el hardware y las aplicaciones se pueden reponer. Además, los datos no públicos deben permanecer **confidenciales** (LOPD):



Ejemplo: Buenas Prácticas a la hora de gestionar activos de información:

https://blog.kawak.net/mejorando_sistemas_de_gestion_iso/gestion-de-activos-de-informacion

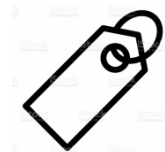
En cuanto a los procedimientos para manipular los activos, hay que prestar **atención especial** a los **soportes de memoria** porque **almacenan la información** sensible.

Gestión de los soportes de almacenamiento (unidades de memoria):

Inventariado de soportes:

Se debe mantener un listado que identifique cada soporte de memoria, además de etiquetarlos con una pegatina que incluya:

- El código identificativo del dispositivo (añadir etiqueta)
- El propietario o usuarios autorizados
- La fecha de entrega
- Su localización actual
- La fecha del último mantenimiento realizado



Soportes extraíbles:

Pueden suponer una brecha de seguridad importante en cuanto a la seguridad de la información.

Se deben establecer procedimientos (políticas) para:

- Requerir autorización para su uso.
- Mantener un registro de altas y bajas de los dispositivos.
- Cifrar los datos para protegerlos (confidencialidad e integridad).
- Renovar los dispositivos periódicamente para evitar la rotura inesperada con la consecuente pérdida de datos.
- Realizar copias de seguridad en otros soportes.
- Controlar la transferencia de información hacia medios extraíbles.
- Analizar los dispositivos en busca de malware para evitar que se propague a otros sistemas.



Pendrive USB que cifra los datos mediante biometría (lector de huellas)

Eliminación de soportes:

Se deben establecer procedimientos (políticas/guías/instrucciones) para:

- Eliminar de forma segura los datos almacenados para que sean irrecuperables (low level format).
- Mantener un registro de los dispositivos dados de baja.
- Cuando el personal abandone la empresa hay que garantizar que devuelve los activos (físicos y lógicos) y que no quedan rastros de datos confidenciales.

Traslado de soportes:

Se debe definir un procedimiento para proteger la información cuando los soportes necesitan ser trasladados entre distintas ubicaciones, teniendo en cuenta aspectos como:

- Mantener un registro de salida de los soportes incluyendo el transportista, el lugar de destino y la duración del transporte.
- Establecer un procedimiento de cifrado cuando sea necesario y posible.
- Controlar los embalajes y las condiciones ambientales .



Ejemplo: formas de propagar malware a través de memorias USB:

<https://www.redeszone.net/2018/03/13/quieres-saber-podrian-infectarte-usb-mira-esta-lista>